

Litigation Chamber

Decision on the merits 166/2024 of December 17, 2024

File number: DOS-2021-06114

Subject: Security measures implemented by a hospital

The Litigation Chamber of the Data Protection Authority (hereinafter "DPA"), composed of Mr. Hielke HIJMANS, president, and Messrs. Romain Robert and Jelle Stassijns, members;

Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), hereinafter "GDPR";

Considering the Law of December 3, 2017, establishing the Data Protection Authority¹ (hereinafter "LCA");

Considering the Internal Rules of Procedure (hereinafter "ROI")² as approved by the House of Representatives on December 20, 2018, and published in the Belgian Official Gazette on January 15, 2019;

Considering the documents in the file;

Has made the following decision regarding:

The defendant: Y, represented by Maitres Victoria Ruelle and Fanny Cotton, hereinafter "the defendant".

1 The DPA reminds that the revised framework law came into force on 01/06/2024. It only applies to complaints, mediation files, requests, inspections, and procedures before the Litigation Chamber initiated from that date. Files initiated before 01/06/2024, such as the present file, are subject to the provisions of the previous version of the LCA accessible here:

<https://www.autoriteprotectiondonnees.be/publications/loi-organique-de-l-apd.pdf>

2 The DPA reminds that the new internal rules of procedure came into force on 01/06/2024. They only apply to complaints, mediation files, requests, inspections, and procedures before the Litigation Chamber initiated from that date. Files initiated before 01/06/2024, such as the present file, are subject to the provisions of the previous version of the ROI accessible here:

<https://www.autoriteprotectiondonnees.be/publications/reglement-d-ordre-interieur.pdf>

Decision on the merits 166/2024 — 2/50

I. Facts and procedure

1.

The defendant is a hospital structure established in Belgium. On [date] 2021, the defendant notified the DPA of a data breach involving ransomware that occurred between the 16th and [date] 2021. On [date] 2021, the defendant made a supplementary notification regarding this data breach.

2. On October 20, 2021, noting that there were serious indications of a practice likely to result in a violation of the fundamental principles of personal data protection, the Management Committee referred the matter to the Inspection Service, pursuant to Article 63, 1° of the LCA.

3. On November 22, 2021, the Inspection Service made a request for information from the defendant as part of an inspection investigation concerning the data breach. On December 22, 2021, the defendant submitted its responses to this request for information.

4. On February 11, 2022, the Inspection Service made a request for additional information as part of this inspection investigation, notably to better assess the technical and organizational measures implemented by the defendant. On March 10, 2022, the defendant submitted its responses to the additional information request.

5. On April 28, 2022, the Inspection Service produced a technological investigation report. On June 20, 2022, the Inspection Service closed the investigation and transmitted the file to the president of the Litigation Chamber in accordance with Article 91, § 1 and § 2 of the LCA.

6. The report contains findings related to the data breach. In particular, the Inspection Service concludes that while the data breach is indisputable following the external intrusion into the

defendant's infrastructure, its extent remains uncertain.

7. The investigation report also contains findings regarding the absence of a data protection impact assessment and the inadequacy of the technical and organizational measures implemented by the defendant. The Inspection Service notes, in broad terms:

a. Finding 1: Violation of Article 35.3 of the GDPR due to the absence of a data protection impact assessment (hereinafter "DPIA");

Decision on the Merits 166/2024 — 3/50

b. Finding 2: Violation of Articles 5.1.f and 32 of the GDPR due to the absence of an effective and formal information security policy at the time of the data breach;

c. Finding 3: Violation of Articles 5.1.f, 24, and 32 of the GDPR due to the ineffectiveness of the policy and/or procedure for updating the security of IT equipment (software);

d. Finding 4: Violation of Articles 5.1.f, 24, and 32 of the GDPR due to other missing security measures, namely:

i. the absence of a genuine training/awareness program for employees;

ii. the absence of a log preservation system for subsequent analysis during incidents;

iii. the absence of systematic audits of the quality of personal data security; and

iv. the weak security of the password for accessing the patient's electronic file.

8. On September 27, 2022, the Litigation Chamber decides, pursuant to Article 95, § 1, 1° and Article 98 of the LCA, that the case can be examined on the merits. On the same day, the defendant is informed by registered mail of the provisions as set out in Article 95, § 2 as well as Article 98 of the LCA. The defendant is also informed, pursuant to Article 99 of the LCA, of the deadline for submitting its conclusions. The deadline for receiving the defendant's response conclusions has been set for November 8, 2022. The defendant requested an extension of the deadline for submitting the conclusions, which was granted on October 14, 2022.

9. On October 8, 2022, the defendant requests by email a copy of the file (Art. 95, §2, 3° LCA), which is transmitted to them electronically on October 14, 2022.

10. On November 22, 2022, the Litigation Chamber receives the defendant's response conclusions. In summary, the defendant presents the following defenses:

-

Regarding the procedure:

a. The irregularity of the referral to the Management Committee by the General Secretariat.

b. The invalidity of the minutes of the Management Committee.

c. The erroneous nature of the serious indications retained by the Management Committee.

Decision on the Merits 166/2024 — 4/50

d. The impossibility of transmitting the notification form within the departments of the APD.

-

On the merits:

a. Finding 1: The defendant asserts that an impact assessment was conducted.

b. Finding 2: The defendant argues that the hospital's information security policy should be understood as one element among a set of documents and procedures established, which constitute the organizational and technical measures of the hospital.

c. Finding 3: The defendant contends that the policy for updating the security of IT equipment consists of consultancy contracts concluded by the hospital to ensure monthly monitoring of its installations, and aims at several measures that were implemented by the hospital after the data breach.

d. Finding 4: The defendant claims that all the alleged missing measures have been implemented.

11. In its conclusions, the defendant expresses its intention to avail itself of the opportunity to be heard, in accordance with Article 98 of the LCA.

12. On June 20, 2024, the parties are informed that the hearing will take place on July 4, 2024.

13. On July 4, 2024, the parties are heard by the Litigation Chamber.

14. On July 22, 2024, the minutes of the hearing are submitted to the parties.

15. On July 29, 2024, the Litigation Chamber receives the defendant's comments regarding the

minutes.

16. On August 13, 2024, the Litigation Chamber informs the defendant of its intention to impose an administrative fine as well as its amount, in order to give the defendant the opportunity to present its arguments in this regard.

17. On September 3, 2024, the Litigation Chamber receives the defendant's response concerning the intention to impose an administrative fine and its amount. The defendant argues that the hospital should be considered a "public authority" within the meaning of Article 53 of the law on the protection of individuals.

3 Article 5 of the Framework Law states: "For the application of this law, 'public authority' means:

1° the federal state, the federated entities, and local authorities;

Decision on the merits 166/2024 — 5/50

regarding the processing of personal data dated July 30, 2018 (hereinafter "Framework Law"), such that it is not possible to impose a fine on it. Furthermore, if the hospital were to be considered a legal entity to which a fine could be imposed, it contests both the principle of imposing a fine and its amount, as established by the Litigation Chamber in the sanction form. It argues that the severity of the offense is low and that the hospital has limited financial capabilities.

II. Motivation

II.1. Context

18. On [date] 2021, the defendant notified the APD of a "ransomware" data breach that occurred between [...] and [date] 2021. On [date] 2021, the defendant made a supplementary notification regarding this data breach.

19. On [date] 2021, the defendant also issued a press release to inform the public that a cyberattack had taken place. It explained that its servers had been affected, paralyzing part of the computer system.

20. The initial and supplementary notifications of the data breach indicated that numerous categories of personal data had been compromised, including special categories of personal data (such as health data) and electronic communication data. Furthermore, the supplementary notification confirmed that the maximum number of individuals affected by the breach was 300,000 and that the level of risk to the rights and freedoms of the affected individuals was "high."

2° legal entities under public law that depend on the federal state, federated entities, or local authorities;

3° individuals, regardless of their form and nature, who:

- have been created specifically to meet general interest needs that are not industrial or commercial in nature; and

- are endowed with legal personality; and

- whose activity is either predominantly financed by the public authorities or bodies mentioned in 1° or 2°, or whose management is subject to control by these authorities or bodies, or more than half of the members of the governing, management, or supervisory body are appointed by these authorities or bodies;

4° associations formed by one or more public authorities referred to in 1°, 2°, or 3°.

4 Article 221§2 of the Framework Law provides that: "Article 83 of the Regulation does not apply to public authorities and their agents or representatives unless they are legal entities under public law that offer goods or services in a market."

5 The facts as presented in this section are based on the conclusions of the defense and the report of the Inspection Service. They are not contested by the defendant.

Decision on the merits 166/2024 — 6/50

21. It emerges from the investigation by the Inspection Service that the intrusion was carried out by a hacker from servers located on the Asian continent, via the Microsoft Exchange email server. The hacker uninstalled the antivirus and subsequently installed malware. In this way, they were able to

create an account with "administrator" access.

22. The hacker then activated BitLocker, blocking all access to the data on the hospital's Windows servers. When someone attempted to connect, access was denied, and a ransom demand appeared. The hacker also changed the passwords of the Windows computer servers to prevent access. The equivalent of 5 gigabytes of information was exported by the hacker during the attack.

23. During the attack, the network connections to the outside were cut off. The Hospital Emergency Plan (hereinafter "HEP") was triggered to ensure the continuity of patient care, except for the hospital's emergency services, which were closed for 3 days, but for which the measures of the HEP allowed for redirecting patients to other emergency services of third-party establishments.

24. In its responses to the questions from the Inspection Service, the hospital confirms that as of September 20, 2021, three days after the data breach, the software that allows access to the patient file was operational at 95%. On [date] 2021, twelve days after the data breach, the email accounts of the staff were operational again, and the hospital considers that it has largely remedied the consequences of the attack.

25. This is the second "ransomware" data breach suffered by the hospital in two and a half years, the first having occurred on [date] 2019. This first breach had been regularly notified to the APD.

II.2. On the procedure

II.2.1. Referral of the Steering Committee by the General Secretariat:

26. The defendant argues in its conclusions that the General Secretariat of the APD is not competent to handle notifications of data breaches under Articles 19 and 20 of the LCA. Consequently, the competence of the General Secretariat to analyze notifications of data breaches and then draft a note for the Steering Committee is not established. In any case, said note should have been sent at least one week before the meeting of the Steering Committee in accordance with Article 4 of the Internal Regulations; however, the note from the General Secretariat is undated.

Decision on the Merits 166/2024 — 7/50

27. The Dispute Chamber recalls that Article 4 of the Internal Rules of Procedure (IRP) provides that "For all cases requiring a strategic decision from the management committee, a proposal is prepared by the competent director through a note. Unless in cases of urgent necessity, the file will be made available to the members at least one week before the meeting, if necessary with the required annexes. During the meeting, the file will be explained by the competent director."

28. The General Data Protection Regulation (GDPR) stipulates in Article 33§1 that "In the event of a personal data breach, the data controller shall notify the breach to the competent supervisory authority..." without distinction of the department or service of the authority competent to handle said breach. The Dispute Chamber notes that neither the Law on the Protection of Personal Data (LCA) nor the IRP assigns exclusive competence to a department of the Data Protection Authority (DPA) to handle notifications of personal data breaches. Contrary to what the defendant claims during the hearing, there is no legal vacuum on this point, as the GDPR provides that such competence lies with the supervisory authorities. If, as in this case, national law does not provide anything, it remains the responsibility of each authority to carry out the missions conferred upon it by the GDPR, in order to give useful effect to the text.

29. The General Secretariat, one of whose executive tasks is to formulate opinions within the framework of Data Protection Impact Assessments (DPIAs) (Article 20§1, 3° of the LCA), has the necessary experience to assess the risks associated with data processing implemented by data controllers. Furthermore, it has the executive task of monitoring technological developments that impact the protection of personal data (Article 20§1, 3° of the LCA), which requires monitoring the technologies used by hackers, which can be described in the data breach notification forms.

30. In fact, the General Secretariat is a department of the DPA with privileged expertise to analyze the risks arising from a data breach notified to the DPA.

31. On the other hand, the director of the General Secretariat has the competence, like any other director, to present a file to the Management Committee for review with a view to possibly activating

Article 63.1° of the LCA. Given the developments outlined above (paragraphs 29 and 30), it appears that the director of the General Secretariat was competent, without excluding that other directors could have done the same, to propose a note to the Management Committee, based on his analysis of the data breach notification form, in accordance with Article 4 of the IRP.

32. Furthermore, the Dispute Chamber observes that while Article 4 of the IRP requires the competent director to submit the file to the members of the Management Committee at least one week before the meeting, the IRP does not require the director to date the note itself. In this case, the DPA proposed to the defendant to acknowledge before the hearing that this provision of the IRP had been observed, since the note was sent by email one week before the meeting of the Management Committee. The defendant did not contest this date during the hearing.

33. In any case, this provision falls under the internal organizational rules of the DPA and cannot lead to the nullity of the procedure, as claimed by the defendant. This time limit, which is an indicative and not mandatory deadline, aims to protect the directors in their functions and not to confer rights to the parties in a procedure. Therefore, this deadline has no effect regarding third parties and cannot be invoked by the defendant to request the annulment of the present procedure. It should also be noted that this deadline was respected.

34. In conclusion, the director of the General Secretariat has validly complied with the procedure prescribed in Article 4 of the IRP by drafting a note to the Management Committee. This note was submitted to the members of the Management Committee at least one week before the meeting. The arguments of the defendant are therefore unfounded.

II.2.2. Minutes of the Management Committee:

35. The defendant explains that there are doubts regarding whether minutes of the decision of the Management Committee were drawn up and signed by the president of the Management Committee, which constitutes a violation of Article 16 of the LCA. Furthermore, she considers that it is not demonstrated that the majority of the members of the Management Committee were present, nor that a majority of the members voted favorably in accordance with Article 3 of the IRP. The defendant also argues that it is not established that the president of the Dispute Chamber abstained from participating in the vote of the Management Committee on this point, as he may subsequently need to take a position on the merits.

36. The Dispute Chamber recalls that the minutes of the Management Committee cover numerous themes, including strategic decisions of the DPA and that they contain personal data. In accordance with the principle of data minimization (Article 5.1.c of the GDPR), and with respect to the principle of...
Decision on the Merits 166/2024 — 9/50

Confidentiality applicable to members of the Steering Committee (art. 48 LCA), the members do not transmit their minutes in full to the parties involved in a procedure, but only an excerpt of said minutes in order to allow the parties to a procedure to assess its existence for the section that concerns them.

37. In the event that a party fears non-compliance with a formality, the APD is willing to provide the additional information requested by a party, in order to allow them to assess the compliance with the contested formalities. Such an opportunity was offered to the defendant before the hearing, in order to allow them to verify the APD's compliance with the formalities they raised under penalty of nullity of the procedure.

38. The defendant was able to ascertain from the minutes that all members of the Steering Committee were present during the deliberation, that no objections from any member of the Steering Committee were noted, and that the minutes were duly signed by the President of the Steering Committee. They were also able to confirm that the Steering Committee decided to refer the matter to the Inspection Service based on article 63.1° of the LCA. The defendant's argument challenging the existence of minutes and the compliance with its formalism is therefore not valid.

39. In accordance with consistent case law, the criticism of bias cannot be based on a situation arising from the normal application of the law (see in this sense the ruling of the Council of State of May 11, 2021). Now, the Steering Committee is composed of the president of the Litigation Chamber (article 12

LCA). The Steering Committee is also competent to refer the matter to the Inspection Service in case of serious indications of the existence of a practice likely to violate the fundamental principles of personal data protection (article 63.1° of the LCA).

40. No article of the LCA provides for an exception regarding the participation of the president of the Litigation Chamber in the decisions made by the Steering Committee. When the president of the Litigation Chamber is excluded from a role or position, the law explicitly provides for it (see articles 13 and 18 of the LCA), proof that the legislator did not intend to exclude the president of the Litigation Chamber from participating in the deliberations of the Steering Committee. The latter is therefore competent to participate in the deliberations of the Steering Committee (art. 16 of the LCA) and to make a decision on the merits (art. 98 and following of the LCA).

7 See the ruling of the Council of State of May 11, 2021, n°250.571 available at the following link: <http://www.raadvst-consetat.be/Arrets/250000/500/250571.pdf#xml=http://www.raadvst-consetat.be/apps/dtsearch/getpdf.asp?DocId=39004&Index;=c%3a%5csoftware%5cdtsearch%5cindex%5carrets%5ffr%5c&HitCount;=2&hits;=16+17+&083572024517>

Decision on the Merits 166/2024 — 10/50

41. The Disciplinary Chamber recalls that in this case, it is sitting collegially, that is to say, with three members. It also recalls that the Management Committee also sat with five members at the time of its deliberation regarding the present procedure. In such situations of collegiality, the Market Court recalls that even if the bias of one member were demonstrated, it does not alone affect the legality of the contested decision.

42. Finally, the alleged bias of a collegial body must be concretely demonstrated, which requires highlighting specific facts or behaviors concerning that body, and thus posed by its members. Regarding the members of the Management Committee and the Disciplinary Chamber, Article 43§2 of the LCA explicitly provides that: "They are prohibited from being present during a deliberation or decision on cases for which they have a personal or direct interest or for which their relatives or allies up to the third degree have a personal or direct interest." These situations of bias are provided for by law.

43. While it is true that the legislator did not foresee a specific recusal regime to guarantee the independence and impartiality of the members of the Disciplinary Chamber, the Disciplinary Chamber is willing to respond to serious arguments presented by parties regarding the bias of these members. In this case, the defendant does not provide any evidence of bias on the part of the president of the Disciplinary Chamber that could have justified their recusal.

44. In conclusion, neither the validity of the minutes of the Management Committee nor the participation of the president of the Disciplinary Chamber in the deliberation can be contested. The procedure complied with legal requirements, and no evidence of bias has been presented.

II.2.3. Serious Indications Retained by the Management Committee:

45. The defendant argues that the indications retained by the Management Committee to establish that there were serious indications of the existence of a practice likely to lead to a violation of the fundamental principles of personal data protection are erroneous. It contests that the reasoning of the Management Committee is established by reference to the note from the General Secretariat. Finally, it explains that the fact that the hospital was the victim of a cyberattack does not stem from any fault on its part and does not constitute a serious indication within the meaning of Article 63.1° of the LCA.

46. The Disciplinary Chamber recalls that under the powers conferred on the Management Committee, it is up to them to determine whether serious indications reveal the existence of practices that may lead to a violation of the fundamental principles of data protection (Article 63.1° of the LCA). As the Market Court has recalled, this is a discretionary power of the DPA.

47. The Council of State accepts reasoning by reference, provided that the document referred to is part of the file, which is the case here (Council of State ruling of May 7, 2013, No. 223.440). Indeed, the decision of the Management Committee refers to the note that was provided to it and is based on it to retain the following indications:

a. The shutdown of the hospital's computer network, which led to the cancellation of scheduled operations and consultations as well as the closure of the emergency services.

- b. The degree of sensitivity of the data involved in the breach, including in particular the national number, the social security identification number, genetic and biometric data, data related to health, care, sexual life or sexual orientation, criminal convictions, extracts from the criminal record, the content of electronic communications, and financial data.
- c. The indication in the form of the possible impact of the data breach on the rights and freedoms of the affected individuals, such as the unavailability of data or treatments preventing the continuation of the expected service.
- d. The large number of people affected, potentially 300,000 individuals.
- e. The existence of a previous significant data breach of the "ransomware" type dated [date] 2019. On this point, the defendant confirmed that no ransom had been paid.

Decision on the merits 166/2024 — 12/50

48. This information was based on the description of the data breach, as outlined in the initial and supplementary notification forms submitted to the DPA by the hospital. It was only through the subsequent investigation conducted by the Inspection Service that the latter was able to somewhat contextualize the extent of this breach and the previous breach from 2019.

49. However, the investigation did not fully clarify the exact circumstances of the breach (see paragraph 106 and following regarding the preservation of logs). In any case, if erroneous information was communicated to the DPA through these notifications, the Management Committee cannot be criticized for using it to characterize serious indications justifying the opening of an investigation. At the time of the Management Committee's decision and based on the elements available to it upon reviewing the initial notification, the Management Committee sovereignly determined that there were serious indications justifying the opening of an investigation. The Litigation Chamber cannot exercise any control over the Management Committee's decision in this regard other than a marginal review. Moreover, the Management Committee did not exceed its powers in assessing the seriousness of the indications in question in this case.

50. Furthermore, the defendant contests that the Management Committee took into account a previous data breach that occurred in 2019 by the same hospital. However, the Management Committee was entitled to rely on the information made available to the DPA through the data breach notification forms received from the hospital. These forms constitute an essential and legitimate source of information for the DPA, allowing for the characterization of serious indications of potential violations of data protection legislation. The recurrence of data breaches within the same institution, particularly when they occur at close intervals and involve high risks to the rights and freedoms of the affected individuals, reasonably strengthens the presence of serious indications within the meaning of Article 63.1° of the LCA.

51. The Management Committee sovereignly assessed that the fact that a hospital experienced two data breaches, each presenting "high" risks to the rights and freedoms of the affected individuals within a span of two years, constituted an additional serious indication revealing the existence of practices that could lead to a violation of the fundamental principles of data protection.

52. Moreover, the defendant seems to confuse the notion of "serious indications" with the finding of a violation of the GDPR. The Management Committee does not have the power to establish a violation of the GDPR, and such a finding is not required for it to invoke Article 63.1° of the LCA. The competence to establish a violation of the GDPR is reserved for the Litigation Chamber. It is only when it has a complete file, which contains the parties' conclusions and a possible investigation report, that the Litigation Chamber can determine whether a cyber attack constitutes a violation of the GDPR. At the time of the activation of Article 63.1°, only the existence of serious indications is necessary, which has been sovereignly assessed (see paragraphs 49 to 51 above).

53. In conclusion, the Management Committee was justified in finding the seriousness of the indications in question sufficient, based on the information provided by the defendant (Article 63.1° of the LCA).

II.2.4. Transmission of the notification form within the departments of the DPA:

54. The defendant argues that the data breach notification form does not need to be shared within the departments of the DPA, due to the absence of a legal provision for this purpose. Furthermore, it

claims that neither the GDPR nor the LCA provide for the possibility of a data breach notification leading to proceedings before the Litigation Chamber. Finally, it asserts that the European Data Protection Board (hereinafter "EDPB") does not foresee that such a notification can be used to justify the referral to the Inspection Service and to accuse the notifier of other breaches.

55. The Litigation Chamber contests the arguments raised in the defense's conclusions and reminds that the GDPR provides, in its Article 33§1, that "In the event of a personal data breach, the controller shall notify the breach to the competent supervisory authority...". Furthermore, "Such notification may lead a supervisory authority to act in accordance with its tasks and powers set out in this Regulation" (recital 87 of the GDPR).

56. Therefore, any supervisory authority is legally authorized to know the content of a data breach notification form that is submitted to it. Contrary to the assertions raised in defense, the GDPR indeed provides that such a notification may lead an authority to exercise its investigation and enforcement powers. Considering the structure of the DPA, this circumstance necessarily justifies the possibility of transmitting the form between its competent services.

12 Litigation Chamber, decision on the merits 170/2023 of December 20, 2023, available at the following link:

<https://www.auditeprotectiondonnees.be/publications/decision-quant-au-fond-n-170-2023.pdf>
Decision on the Merits 166/2024 — 14/50

57. Even if the defendant considers that Recital 87 of the GDPR is not sufficiently explicit, the Contentious Chamber recalls that when a provision of European Union ("EU") law is susceptible to multiple interpretations, priority must be given to the interpretation that is likely to preserve its useful effect, according to the general principles of EU law. The interpretation of EU law must be carried out in a manner that ensures the effectiveness of the EU legal system and avoids provisions being rendered meaningless. The defendant's argument that the Data Protection Authority (DPA) did not have to transmit the data breach notification form between the departments involved in the follow-up of this case is therefore unfounded.

58. Finally, contrary to the defendant's allegations, the guidelines of the European Data Protection Board (EDPB) on the calculation of administrative fines under the GDPR confirm the possibility for the supervisory authority to use a data notification that has been transmitted to it. These guidelines explicitly state that when the supervisory authority becomes aware of a breach justifying the imposition of a fine through a notification of a data breach, this factor should be considered neutral in the calculation of the fine.

59. In conclusion, the data breach notification form was validly shared within the DPA departments to enable them to exercise their investigation and prosecution powers.

II.3. On the Merits

II.3.1. Finding 1: On the Data Protection Impact Assessment

60. First, the defendant argues that since the processing related to the electronic messages of staff was the only processing affected by the data breach, it was not subject to the obligation to carry out a Data Protection Impact Assessment (DPIA) for this processing, which does not require the processing of sensitive data. During the hearing, the Contentious Chamber further questioned the defendant on its reasoning asserting the absence of processing of sensitive data in the context of the processing of electronic messages of hospital staff. The defendant maintained that sensitive data were likely exchanged via electronic messages but stated that this sensitive data was encrypted.

61. Secondly, it argues that the performance of a DPIA does not have to take a specific form, and that it is incorrect to assert that no DPIA was conducted since the hospital implemented security measures that are the result of risk analyses.

62. Thirdly, it claims that since the processing was implemented before the entry into force of the GDPR in May 2018, it is not subject to the obligation to carry out a DPIA, and even if it were, it would have been exempted from this obligation due to the "grace period" of three years granted by the

EDPB.

63. First, the Contentious Chamber recalls that a DPIA is required in several cases, notably in the case of large-scale processing of special categories of data (Article 35.3.b of the GDPR). A DPIA must at least contain (Article 35.7, and Recitals 84 and 90 of the GDPR):

- a. a systematic description of the envisaged processing operations and the purposes of the processing;
- b. an assessment of the necessity and proportionality of the processing operations;
- c. an assessment of the risks to the rights and freedoms of the data subjects;
- d. the measures envisaged to:
 - i. address the risks;
 - ii. demonstrate compliance with the GDPR.

64. In this case, the data controller processes sensitive data (including health data and genetic data) of vulnerable individuals (patients) on a large scale (300,000 patients in the database), which imposes upon it the obligation to comply with this requirement. The Contentious Chamber recalls that one of the purposes of conducting a DPIA is to allow the data controller to proactively identify security weaknesses and adopt appropriate measures to protect personal data against data breaches.

Decision on the merits 166/2024 — 16/50

65. Contrary to the defendant's allegations, the fact that the attack focused on the staff's email rather than on the patients' medical records does not exempt the defendant from its duty to conduct a DPIA (Data Protection Impact Assessment). The Litigation Chamber reminds that the definition of "processing" under the GDPR is broad and includes, in particular, the storage, collection, consultation, use, and provision of personal data (Article 4 of the GDPR). Even if the attack only targeted the staff's email accounts, the fact that these accounts allow for the processing of sensitive data of vulnerable individuals on a large scale imposes on the defendant the obligation to comply with its duty to conduct a DPIA concerning this processing, regardless of whether this data is encrypted during the sending of emails. In any case, this finding is not limited to examining the conduct of a DPIA concerning the specific processing related to the staff's email accounts.

66. Furthermore, it appears irrelevant on the part of the defendant to claim that only the staff's email accounts were affected, as it emerges from the investigation report that the hospital's servers were paralyzed (including the software supporting the medical records), and that it ceased to be operational due to the attack. Moreover, it is clearly indicated in the investigation that traces were found on the "radiology server." According to the defense's conclusions: "The Hospital was able to gradually but quickly restart its services without risks, including the radiology service," and "Finally, the thorough investigations conducted by the Hospital and the service providers it engaged showed that during the attack, only 5 gigabytes of information were exported from one of the Hospital's servers to the Internet. However, the server in question contains all the X-rays (...)." Therefore, the data breach indeed involved sensitive categories of personal data, namely the health data of the hospital's patients processed on a large scale.

67. Secondly, it is inaccurate to assert that the DPIA does not need to take a particular form, as the principle of accountability under the GDPR requires data controllers to be able to demonstrate that their obligations are met (Articles 5.2 and 24 of the GDPR) and that Article 35.7 of the GDPR lists the minimal content of a DPIA. It follows that the DPIA must be carried out in a separate document that does not overlap with any other potential risk analyses. The analyses of

16 In accordance with Article 35.1 of the GDPR, it is the responsibility of the data controller to determine whether it is appropriate to conduct one or more DPIAs: "A single analysis may cover a set of similar processing operations that present similar high risks."

Decision on the merits 166/2024 — 17/50

The risks presented by the defendant do not meet the necessary criteria for the establishment of a DPIA by the Litigation Chamber.

68. In any case, the defendant confirmed in its responses to the questions from the Inspection Service

that no DPIA had been conducted by the data controller. The fact that risk analyses were carried out by the hospital's auditors and that a DPIA was commissioned does not allow the Litigation Chamber to consider that a DPIA was conducted by the defendant.

69. Thirdly, the defendant wrongly argues that since the processing was implemented before the entry into force of the GDPR in May 2018, it is not subject to the obligation to conduct a DPIA. Regarding processing operations established before the entry into force of the GDPR, the Litigation Chamber recalls that the EDPB states that "The obligation to carry out a DPIA applies to existing processing operations [established before the GDPR] that are likely to result in a high risk to the rights and freedoms of natural persons and for which the associated risks have evolved, taking into account the nature, scope, context, and purposes of the processing" (emphasis and information in brackets added).

70. Given that the risks in the hospital sector are constantly evolving (a fact not contested by the defendant) and that the stakes of a disruption of hospital activities present a high risk to the rights and freedoms of natural persons, the Litigation Chamber refutes the argument that the hospital would have been exempt from the obligation to conduct a DPIA.

71. Finally, the Litigation Chamber contests the defendant's assertions raised during the hearing, according to which the EDPB would have granted a grace period of 3 years regarding the conduct of DPIAs for existing processing operations following the entry into force of the GDPR. While such a grace period may have been authorized by national authorities under specific conditions, such as the National Commission for Information Technology and Civil Liberties (CNIL) in France, the EDPB did not grant such a period.

17 See the EDPB guidelines on data protection impact assessment (DPIA) and how to determine whether processing is "likely to result in a high risk" for the purposes of Regulation (EU) 2016/679, available at the following link: <https://ec.europa.eu/newsroom/article29/items/611236/en> (page 16)

18 The defendant itself argues in its conclusions that hospitals are subject to specific and constantly evolving risks: "(...) hospital structures are prime targets for hackers," "Hackers are numerous, have inexhaustible resources, and particularly target hospital groups."

19 As recalled in the guidelines on data breach notification from WP29: "If critical medical data concerning patients of a hospital becomes unavailable, even temporarily, this could pose a risk to the rights and freedoms of the individuals concerned; operations could for example be canceled and lives put in danger." These Guidelines on the notification of personal data breaches under Regulation (EU) 2016/679 were published by WP29 (the predecessor of the EDPB). They are accessible at the following link: <https://ec.europa.eu/newsroom/article29/items/612052/en> (see page 9)

Decision on the Merits 166/2024 — 18/50

In any case, the hospital still did not have a DPIA more than three years after the entry into force of the GDPR, that is, on May 25, 2018²⁰. The argument related to the existence of an alleged grace period – quod non – cannot therefore be convincing.

72. In conclusion, the defendant failed to fulfill its obligation to conduct a DPIA within the meaning of Article 35.3 of the GDPR.

II.3.2. Finding 2: On the effective and formal information security policy

73. First, the defendant argues that the Data Protection Authority (DPA) is not competent to monitor compliance with the obligation to apply the minimum standards relating to information security and privacy for social security institutions under Article 2, paragraph 1, 2° of the law of January 15, 1990, concerning the establishment and organization of a Crossroads Bank for Social Security (hereinafter, the "Minimum Standards")²¹. Secondly, it argues that the GDPR does not contain any formal obligation to have an information security policy, and does not impose, a fortiori, any formalism for such a policy. It explains that in this case, the hospital's information security policy should be understood as one element among a set of documents and procedures established, which constitute the organizational and technical measures of the hospital.

74. First, the Litigation Chamber recalls that under Article 32.1 of the GDPR, it is the DPA's responsibility to verify compliance with appropriate technical and organizational measures, taking into account "the state of the art." The aforementioned Minimum Standards, which have binding force for

social security institutions regarding the security of personal data in Belgium, constitute a useful reference to "the state of the art" to which the Litigation Chamber can refer. Indeed, these standards provide that: "Moreover, it is good practice for these standards to also apply to information security and privacy in the broadest sense of the term (...)"²².

20 The date of entry into force of the GDPR is May 25, 2018, whereas the attack occurred on [...] 2021, more than three years later.

21 The Minimum Standards for information security and privacy, in their version of March 7, 2017, are accessible at this link: [https://www.ksz-bcss.fgov.be/sites/default/files/assets/protection des donnees/mnm normes minimales.pdf](https://www.ksz-bcss.fgov.be/sites/default/files/assets/protection%20des%20donnees/mnm%20normes%20minimales.pdf)

22 See the aforementioned Minimum Standards, accessible from the following link: [https://www.ksz-bcss.fgov.be/sites/default/files/assets/protection des donnees/mnm normes minimales.pdf](https://www.ksz-bcss.fgov.be/sites/default/files/assets/protection%20des%20donnees/mnm%20normes%20minimales.pdf), page 3, of which the complete passage is reproduced here: "Moreover, it is good practice for these standards to also apply to information security and privacy in the broadest sense of the term, as provided in the royal decree of March 17, 2013, concerning security advisors established by the law of August 15, 2012, relating to the creation and organization of a federal service integrator and as included in the royal decree of August 12, 1993, concerning the organization of information security in social security institutions: 'strategy, rules, procedures, and means of protection of all types of information both in the systems of...

Decision on the merits 166/2024 — 19/50

75. Furthermore, the Dispute Chamber notes that the hospital's 2022 information security policy (see paragraph 78) contains an obligation to comply with the Minimum Standards. Thus, the defendant's failure to comply with the security obligations contained in these Minimum Standards constitutes, in itself, a breach of the technical and organizational measures that the defendant was supposed to implement. The defendant's preliminary remark is therefore unfounded, and the Dispute Chamber will take the Minimum Standards into account in its developments.

76. Secondly, the Dispute Chamber recalls that the GDPR requires the data controller to process personal data in a manner that ensures appropriate security, using suitable technical or organizational measures (Article 5§1.f of the GDPR), hereinafter referred to as "integrity and confidentiality principles." Article 32 of the GDPR provides further details on these technical and organizational measures, for example, the obligation of the data controller to ensure that these measures guarantee a level of security appropriate to the risk. Furthermore, Article 5.2 of the GDPR states that "The data controller is responsible for compliance with paragraph 1 and is able to demonstrate that it is complied with." This principle is known as the principle of accountability.

77. It notes that the defendant has provided numerous documents intended to establish, taken together, the existence of a hospital information security policy (for example, the hospital staff work regulations, the PUH, etc.).

78. The information security policy of March 3, 2022: The Dispute Chamber takes note of the transmission of the aforementioned information security policy, the first version of which is dated March 3, 2022. During the hearing, the defendant confirmed that prior to this date, the information security policy consisted of a set of documents (see paragraph 84). However, the establishment of a set of documents without any connection between them, nor references to each other, with purposes unrelated to the implementation of the technical and organizational measures provided for by the GDPR, does not constitute "appropriate technical and organizational measures" to address risks, within the meaning of Article 32.1 of the GDPR. Furthermore, the Minimum Standards to which the 2022 information security policy refers require having a formal policy: "Every organization must have a formal and updated information security policy, approved by the person responsible for daily management" (emphasis added).

79. The Dispute Chamber notes that this very general policy itself states that it is a "baseline document." This baseline document requires "Developing a clear and precise policy regarding information security and privacy, validating it, communicating it, and updating it to ensure availability,

integrity, and confidentiality in accordance with the objectives of Y."

Decision on the merits 166/2024 — 20/50

80. The Dispute Chamber further notes that this baseline document was established after the data breach and cannot be considered by the Dispute Chamber as justifying the existence of such a policy at the time of the data breach. Moreover, it does not constitute a comprehensive or final document, in the sense that it refers to other documents to clarify its application. This baseline document alone is not sufficient to fully meet the requirements for implementing appropriate organizational measures within the meaning of Article 32.1 of the GDPR, and it was also established after the breach.

81. The clear and precise policy regarding information security and privacy: The defendant confirmed during the hearing that the "clear and precise" policy regarding information security, which it was supposed to implement according to the aforementioned baseline document, has not been established. It further maintains that its security policy remains composed of a set of documents (see paragraph 84).

82. The Dispute Chamber finds that the purpose of this clear and precise policy was to detail the implementation of the defendant's technical and organizational measures. Indeed, the information security policy of March 3, 2022 states: "The following paragraphs present, without going into the details of implementation, the main management measures governing the management of information security of Y." The Dispute Chamber finds that it is unable to fully assess the technical and organizational measures implemented in accordance with the objectives of Y, due to the absence of this clear and precise policy.

83. The Dispute Chamber does not consider that the establishment of a set of documents as described in paragraph 77 fulfills the requirement to implement "appropriate technical and organizational measures." The establishment of a "clear and precise policy" would have allowed for the fulfillment of this requirement, which it did not. It therefore finds a breach of Article 32.1 of the GDPR.

Decision on the merits 166/2024 — 21/50

84. The entirety of documents submitted by the defendant: The majority of the documents submitted were established after the second data breach. Their usefulness in the context of the present proceedings is therefore limited to the influence that this late establishment would have regarding the determination of a potential sanction, particularly the assessment of the amount of a potential fine. They do not allow the Litigation Chamber to assess the level of compliance of the defendant, either with the principles of integrity and confidentiality, or with the security requirements of the GDPR, at the time of the second data breach.

85. Regarding the official documents whose date allows for demonstrating that they were in place at the time of the second breach, the Litigation Chamber notes that none of these documents are intended to demonstrate the hospital's compliance with Articles 5.1(f) and 32 of the GDPR. The APD recalls in this regard that the data controller must be able to demonstrate that the principles set out in Article 5.1 of the GDPR are respected.

86. For example, the PUH aims to define procedures for the effective management of a sudden influx of patients without jeopardizing the care provided to already hospitalized patients. The staff IT charter is a contractual measure allowing the data controller to impose certain obligations on the hospital staff.

87. The APD does not consider such documents as constituting an information security policy that would demonstrate that the technical and organizational measures determined by the data controller ensure a level of security appropriate to the risk, in compliance with the GDPR. Only a formal and updated information security policy can allow the data controller to demonstrate its level of compliance with the GDPR's security requirements, provided that its content is complete, effectively adapted to the risk, and properly implemented.

88. In conclusion, the defendant is unable to demonstrate its compliance with Articles 5.1(f) and 32 of the GDPR, through a formal and updated information security policy at the time of the data breach.

II.3.3. Finding 3: On the policy and/or procedure for updating the security of IT equipment (software)

89. The defendant argues that the policy for updating the security of IT equipment consists of

consultancy contracts concluded by the hospital to ensure monthly monitoring of its installations. Furthermore, it mentions several measures that were implemented by the hospital after the data breach, including the establishment of a Web Application Firewall in March 2022.

90. The Litigation Chamber emphasizes that the defendant neither explains in its responses to the Inspection Service, nor in its conclusions what the policy and/or procedure for updating the security of IT equipment (software) was in place at the time of the data breach.

91. The investigation report revealed that the security flaw exploited by the hacker was due to a vulnerability on the Microsoft Exchange server. The exploitation of this flaw allowed the hacker to launch their attack and encrypt a set of accessible servers. The fact that only firewalls and anti-virus gateways were monitored was not sufficient to prevent the exploitation of such security flaws.

92. In fact, it emerges from the Inspection Service's investigation that the vulnerability exploited by the hacker was considered "critical" due to its ease of exploitation. In light of the responses provided, the defendant does not demonstrate that this type of risk could have been detected and managed at the time of the data breach.

93. In addition to the principles of integrity and confidentiality, and the security requirements (Articles 5.1(f) and 32 of the GDPR), the GDPR requires the data controller to review and update the technical and organizational measures in place, if necessary (Article 24 of the GDPR). The EDPB lists proper patch management as one of the most important security measures in its guidelines 01/2021 of December 14, 2021, regarding examples of notification of data breaches (cf. paragraph 18)²³. The Minimum Standards also remind that: "Every organization must install a system and formal and updated procedures for detecting, monitoring, and repairing security breaches proportionate to the technical/operational risk."

94. It emerges from the report of the Inspection Service that the data controller had not implemented measures capable of alerting it to the fact that its processing of

23 EDPB, Guidelines 01/2021, Examples regarding the notification of personal data breaches, adopted on December 14, 2021, v2.0, available at the following link: https://www.edpb.europa.eu/system/files/2022-09/edpb_guidelines_012021_pdbnotification_adopted_fr.pdf

See also in this regard, the previous version of these guidelines (for public consultation), from January 14, 2021, which already mentions these recommendations in paragraph 18: https://www.edpb.europa.eu/sites/default/files/consultation/edpb_guidelines_202101_databreachnotificationexamples_v1_en.pdf
Decision on the merits 166/2024 — 23/50

Personal data did not guarantee appropriate security against risks. Despite the provisions of Article 24 of the GDPR, and the obligation imposed on the data controller to demonstrate compliance with the fundamental principles of the GDPR under Article 5.2 of the GDPR, the defendant does not demonstrate what technical and organizational measures were in place at the time of the data breach regarding software security, nor how these measures were subject to any review or update.

95. Even though the defendant lists a large number of measures that were implemented, these were only put in place after the breach.

96. In conclusion, the Contested Chamber considers that the defendant failed to fulfill its obligation to establish a policy and/or procedure for updating the security of IT equipment (software) at the time of the data breach, and thus violated Articles 5.1.f), 32, and 24 of the GDPR due to the inadequacy of these technical measures and their updating.

II.3.4. Finding 4: On other security measures

On the employee training/awareness program

97. The defendant argues that the hospital has a "real employee awareness program," which includes training on phishing conducted following the first data breach in 2019, the IT charter provided to employees upon hiring, their confidentiality obligations, security exercises, training on the PUH, and participation by some employees in Cyber-Europe days.

98. The Contested Chamber recalls that Article 32 of the GDPR imposes on the data controller the obligation to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk. Article 5 requires that personal data be processed in a manner that ensures appropriate security of personal data. Furthermore, Article 24 of the GDPR specifies that the data

controller must review and update these measures as necessary.

99. Employees of a hospital who are in contact with special categories of personal data must receive appropriate and regular training regarding the minimum security standards to be observed in the processing of such data, depending on the relevance to their role or function.

100. This ongoing training is an integral part of the organizational measures that must be implemented by the hospital to ensure data security. It must be regularly updated to prevent the risks of data breaches.

Decision on the merits 166/2024 — 24/50

Indeed, in a context where hospitals are subject to increasing threats of cyberattacks, it is essential to maintain up-to-date training to ensure compliance with regulatory requirements and effectively protect personal data.

101. Contrary to the defendant's claims, the Contested Chamber cannot consider that a genuine employee training/awareness program has been established by the hospital. None of the documents cited in paragraph 97, even taken together, constitutes a genuine continuous and systematic training program on the GDPR as required by Article 32 of the GDPR. Training on phishing, while useful, is not sufficient to cover the important aspects of personal data protection.

102. Furthermore, the IT charter provided upon hiring and the confidentiality obligations, without regular follow-up and relevant updates, do not allow for the conclusion that employees are regularly informed of best practices regarding data confidentiality protection, especially as risks are constantly evolving.

103. Security exercises and training on the PUA do not aim to provide training on the principles of protection and security of personal data. Finally, the occasional participation of some employees in Cyber-Europe days does not replace a structured and continuous training program for all staff. The hospital demonstrates no proactive and regular approach to training/raising awareness among its staff regarding the specific requirements of the GDPR.

104. During the hearing, the defense explained that staff members have the opportunity to attend cybersecurity training. Hospital staff attended Cyberweek in October 2023, which focused on cybersecurity in the healthcare sector. It also justifies the involvement of an external provider, which allowed for the training of about twenty "GDPR champions." The Contested Chamber acknowledges these efforts and confirms that they are moving in the right direction, but it must be noted that this training applies only to a tiny proportion of the staff and was implemented after the data breach.

105. In conclusion, the hospital did not have a genuine employee training/awareness program on the GDPR and thus violated Articles 32, 5.1.f), and 24 of the GDPR.

On the log preservation system for subsequent analysis during incidents

Decision on the merits 166/2024 — 25/50

106. The defendant asserts that the hospital has a log preservation system, which was implemented prior to the data breach. However, it admits that the attacker deliberately deleted part of these logs in an attempt to erase traces of their presence. During the hearing, the defendant stated that the logs were not deleted (contrary to the defense presented in its conclusions), but "encrypted" by the attacker.

107. The Contested Chamber recalls the obligation imposed on the data controller to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including the ability to ensure the confidentiality, integrity, availability, and constant resilience of processing systems and services (32.1.b) of the GDPR). This also includes the ability to preserve logs for subsequent analysis in the event of data breaches.

108. The Contested Chamber notes that the defendant seems to confuse the concepts of log journaling and log preservation. The preservation of logs, in question here, is specifically aimed at preventing the deletion or encryption of logs. This preservation is crucial for analyzing actions taken on personal data retrospectively. In principle, such a log preservation system should allow for determining within a reasonable timeframe who accessed which information, when, and how, as well as identifying the nature of the information consulted and the precise identification of the individual. These logs

should be stored separately on distinct equipment, protected against encryption, thus ensuring reliable and secure traceability. The Contested Chamber recalls that the aforementioned Minimum Standards contain precise and specific requirements regarding log preservation, which constitute good practice to follow when implementing such a system.

109. In this case, the defense confirms in its conclusions that the attacker deliberately deleted part of these logs in an attempt to erase traces of their presence, except for one server (radiology) where they left clues. This lack of log preservation makes it difficult to understand the attack, identify the exploited vulnerabilities, and assess the compromised data. The defendant explains that during the data breach, the firewall logs were not deleted, and their analysis confirmed that "these are probably actions and commands that were exported by the attackers, not personal data." However, in the absence of log preservation, it is impossible for the defendant to demonstrate such hypotheses.

Decision on the merits 166/2024 — 26/50

110. During the hearing, the defendant argues, contradicting these conclusions, that the logs were not "deleted," but "encrypted." Even if the logs had been encrypted rather than deleted, the defendant demonstrates that the logs could not have been preserved for subsequent analysis.

111. This situation highlights a lack, or at the very least, an insufficiency in the hospital's log preservation system at the time of the data breach (see in this regard paragraphs 19, 28, and 49 of the EDPS Guidelines 01/2021, concerning examples of notification of personal data breaches).

112. During the hearing, the defendant explained that all improvements made to the backups taken by the hospital now prevent the deletion of logs, and that if they are deleted, they can now be recovered. The Contested Chamber takes note of the implementation of this technical measure, even though its implementation comes late, especially considering that a first data breach had already occurred in 2019.

113. Therefore, at the time of the data breach, the hospital violated the security requirements of Articles 5.1.f), 24, and 32 of the GDPR by failing to implement adequate measures to preserve logs against malicious deletions or encryption, thereby compromising the ability to detect and analyze data breaches for subsequent documentation.

On systematic audits of the quality of personal data security

114. The defendant explains that it has taken contractual measures to ensure that various service providers are involved in auditing the hospital's systems, security, and data quality. These measures were taken after the second data breach.

115. The Contested Chamber recalls that Article 32.1.d) of the GDPR proposes a series of technical and organizational measures, including, as necessary, a procedure for regularly testing, analyzing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

116. An audit of the quality of data security allows for analyzing IT infrastructures and identifying weaknesses in information management systems (including personal data), notably hardware, software, data, and procedures, in order to ensure an adequate level of security relative to the risk. A detailed audit report enables the data controller to be aware of vulnerable areas exposed to cybercriminals. Based on such a

Decision on the merits 166/2024 — 27/50

report, a risk mapping is established and adequate security measures are recommended to reduce the identified risks.

117. The Minimum Standards remind that every organization must "periodically conduct a compliance audit of the situation regarding information security and privacy as described in the policies," and this at least once a year. The investigation conducted by the Inspection Service demonstrated that no audit of the quality of personal data security had been performed at the time of the breach. The documents provided by the defendant show that several audits were conducted after the data breach.

118. However, these subsequent audits are insufficient to demonstrate that the hospital exercised the necessary diligence to prevent data breaches through systematic audits prior to the second data breach. This lack of audits may have contributed to the occurrence of the second data breach,

revealing a deficiency in the proactive management of personal data security. Furthermore, the Dispute Chamber invites the hospital to ensure that the audits implemented after the second data breach meet the requirements outlined in paragraph 116.

119. In conclusion, the defendant failed in its security obligation by not implementing regular and systematic audits to test, analyze, and evaluate the effectiveness of technical and organizational measures at the time of the breach, and to ensure the security of data processing as required by Articles 32, 24, and 5.1.f) of the GDPR.

On the security of the access password to the computerized patient file

120. The defendant believes that it has strong security measures for the access passwords to the computerized patient files. It explains that to access the computerized patient files, each user must have access to the hospital's dedicated software installed locally on the hospital's computers and other devices, and must fill out an access request form. This form requires an identifier and the creation of a password by the user. At the time of the attack, this password had to contain between 6 and 8 characters, and not correspond to the user's first name, last name, department, or initials. The hospital explains that it relies on its medical records management software provider to define the password criteria.

121. The Dispute Chamber reminds that the GDPR requires the data controller to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk. These measures

Decision on the merits 166/2024 — 28/50

include, among other things, the ability to ensure the ongoing confidentiality of processing systems and services (Article 32.1.b of the GDPR).

122. In a hospital context, where the protection of patients' health data is crucial, a very robust password is necessary. Recommendations on password security can be found in standards such as those from the European Union Agency for Cybersecurity (ENISA) and the guidelines from the National Institute of Standards and Technology (NIST). Furthermore, the Information Security & Privacy Protection Note: Summary and Practical Rules on Medical Data Protection, dated July 14, 2017, developed based on discussions within the "medical data" working subgroup of the Information Security Committee, states that "A sufficiently long password has a minimum of 12 characters." However, a password of 6 to 8 characters is weak. It cannot withstand brute force attacks and does not constitute a strong means of authentication.

123. The defense argues in its conclusions that the password policy has been strengthened within the hospital, and that it must now be at least 8 characters long. However, based on the demonstrations in the previous paragraph, the Contested Chamber considers the length of such a password to be insufficient based on the criteria set out in Article 32.1 of the GDPR, particularly in light of the state of knowledge, the context, and the risks faced by the hospital.

124. Furthermore, while the defendant claims that each user must have access to the hospital's dedicated software and fill out an access request form to justify the adequacy of their password security, the Contested Chamber invites the defendant to consider implementing a two-factor authentication mechanism, viewed as a technical measure appropriate to the risks. As recalled in the guidelines on data breach notification from WP29: "If critical medical data concerning patients of a hospital becomes unavailable, even temporarily, this could pose a risk to the rights and freedoms of the individuals concerned; operations could, for example, be canceled and lives put in danger."

125. Moreover, the fact that the hospital was reliant on insufficient password criteria defined by its provider means that the hospital has engaged a subcontractor.

24 See the category "Supplementary Documents," and "NOTE MEDSEC Summary and Rules on Medical Data Protection," accessible here:

<https://www.ksz-bcss.fgov.be/fr/protection-des-donnees/politique-de-securite-de-l-information>

25 These Guidelines on the notification of personal data breaches under Regulation (EU) 2016/679 were published by WP29 (the predecessor of the EDPS). They are accessible from the following link: <https://ec.europa.eu/newsroom/article29/items/612052/en> (see page 9)

Decision on the merits 166/2024 — 29/50

contractor who presented insufficient guarantees regarding the implementation of appropriate technical and organizational measures.

126. In conclusion, the defendant did not take into account the criteria of Articles 32, 5.1.f) and 24 of the GDPR to adjust the robustness of the password to the level of security required to protect access to computerized patient records.

III. Sanctions

III.1. On the legal qualification of the defendant

127. The Disciplinary Chamber took into account the responses provided by the defendant to the sanction form and the statutes of the hospital²⁶ in its analysis.

128. Article 221§227 of the Framework Law contains an exception regarding the imposition of a fine on "public authorities," under certain conditions. The notion of "public authority" is defined in Article 528 of the Framework Law. The relevant criteria of Article 5.3° of the Framework Law raised by the defendant to demonstrate that the defendant should be classified as a "public authority" will be analyzed successively below.

129. As a preliminary matter, it is undisputed that the hospital has legal personality as a Non-Profit Association (hereinafter "ASBL"), in accordance with the second condition of Article 5.3° of the Framework Law.

Specific satisfaction of general interest needs

26 [...]

27 Article 221§2 of the Framework Law provides that: "Article 83 of the Regulation does not apply to public authorities and their agents or representatives unless they are legal entities under public law that offer goods or services on a market."

28 Article 221§2 of the Framework Law provides that: "Article 83 of the Regulation does not apply to public authorities and their agents or representatives unless they are legal entities under public law that offer goods or services on a market."

28 Article 5 of the Framework Law provides that: "For the application of this law, 'public authority' means:

1° the federal state, the federated entities, and local authorities;

2° legal entities under public law that depend on the federal state, federated entities, or local authorities;

3° persons, regardless of their form and nature, who:

- have been created to specifically meet general interest needs that are not industrial or commercial in nature; and

- have legal personality; and

- whose activity is either predominantly financed by the public authorities or bodies mentioned in 1° or 2°, or whose management is subject to control by these authorities or bodies, or more than half of the members of the governing, management, or supervisory body are appointed by these authorities or bodies;

4° associations formed by one or more public authorities referred to in 1°, 2°, or 3°."

Decision on the Merits 166/2024 — 30/50

130. The defendant primarily relies on the social purpose of the hospital as defined in its statutes, which aims to "improve the material and moral well-being of the inhabitants of (...)," to demonstrate that the hospital meets needs of general interest, in accordance with the first condition of Article 5.3° of the Framework Law.

131. However, according to the Litigation Chamber, this formulation as it emerges from the social purpose is not sufficient to establish that the hospital was created "specifically" for needs of general interest, as required by Article 5.3° of the Framework Law.

132. Indeed, the courts have recognized that hospitals pursue an economic purpose in a sustainable manner, even if this is usually in support of their ostensibly altruistic objectives. It is therefore clear that their activity, although covered by an altruistic framework, is part of an approach where financial viability and the pursuit of economic efficiency are important components, even if the hospital is

constituted in the form of a non-profit association (ASBL). Consequently, the creation of these entities is not exclusively oriented towards meeting needs of general interest, but also incorporates economic considerations that cannot be ignored in assessing their legal qualification under Article 5.3 of the Framework Law.

133. The hospital was not created "specifically" for needs of general interest and follows its own economic logic, such that the first condition of Article 5.3° of the Framework Law is not met.

Hospital Financing:

134. In its response to the sanction form, the defendant detailed the hospital's revenues in the form of five main sources of income, of which nearly all would, according to it, be funding from public authorities, such that the last condition of Article 5.3° of the Framework Law would be fulfilled.

135. Three of the five sources of income come from public authorities. However, two sources of funding deserve detailed analysis. These represent the majority of the hospital's funding based on the figures reported by the defendant. Indeed, according to the figures provided by the defendant, nearly half (..) of its revenues come from "physician fees" and (..) from "sales of pharmaceutical products."

29 See on this point the case Civ. East Flanders (div. Ghent) (2nd ch.) of April 27, 2015, which recalls that the actors in what is called the "social profit sector," such as hospitals, most often fall under the notion of "enterprise," as they pursue an economic purpose in a sustainable manner, even if this is usually in support of their ostensibly altruistic objectives. In this case, the fact that the plaintiff was in the form of a non-profit association did not hinder this. It was considered an enterprise, even without a profit motive.

30 The revenues for 2021 and 2023 were provided by the defendant. The Litigation Chamber used the figures reported in 2023, even though the analysis would have been very similar with the figures from the 2021 fiscal year.

Decision on the Merits 166/2024 — 31/50

136. According to the defendant:

a. The fees of doctors, billed primarily to the INAMI³¹ through the insurance organizations (Mutualities and CAAMI³²), consist of billing for services and therapeutic acts of healthcare providers to Social Security.

b. The revenues related to the sale of pharmaceutical products result from the billing of medications primarily to the INAMI through the insurance organizations (Mutualities and CAAMI) and to patients, where applicable, in the form of packages.

137. Still according to the defendant: "Although the Mutualities are legal entities of private law, they are primarily funded by the INAMI, a legal entity of public law dependent on the federal State, through the mandatory insurance that intervenes predominantly." Thus, the defendant considers that the source of funding for the hospital is overwhelmingly public since it comes from the INAMI, so the hospital should be classified as a public authority.

138. The Litigation Chamber does not follow this reasoning. Certainly, the INAMI is a public institution, but its role is limited to reimbursing a portion of the care provided to patients under the mandatory health insurance. This mechanism does not involve direct funding of hospitals but falls under a complex system in which every citizen is required to subscribe to health insurance to obtain the right to a state contribution to their costs, under social security. The third-party payment system allows patients to benefit from care without having to advance the total costs, but this does not imply that the hospital itself is directly funded by the INAMI.

139. This unique reimbursement system is fundamentally distinct from the concept of funding referred to in Article 5.3° of the Framework Law. Thus, the hospital is not predominantly funded by the public authorities or organizations mentioned in 1° or 2° of Article 5 of the Framework Law. The last condition of Article 5.3° of the Framework Law concerning predominant funding by public authorities is not met. The management is subject to public authority control:

31 The INAMI is the National Institute for Health Insurance and Disability. It is a federal institution.

32 In the event that an insured person is not affiliated with a mutual, the Auxiliary Health Insurance

Fund (CAAMI), a public social security institution, intervenes under the mandatory insurance. It represents 100,000 members or 1% of the market. This source of funding is public, which is not contested by the Litigation Chamber.

Decision on the Merits 166/2024 — 32/50

140. According to the defendant, the Belgian hospital system is organized by public authorities. It argues that the Walloon Agency for Quality of Life (“AVIQ”) is the regional public service responsible for managing the accreditation granted to regional hospitals and for their inspection. Therefore, the management of the hospital is subject to public authority control according to the defendant. Furthermore, it considers that public authorities control both at the entry (tariffs charged by hospitals) and at the exit (expenses incurred).

141. The Litigation Chamber once again rejects the arguments put forward by the defendant, clearly distinguishing between the concepts of regulation and effective control of management. Certainly, the Walloon Agency for Quality of Life (“AVIQ”) carries out an inspection and accreditation mission, but these functions fall solely under regulatory supervision aimed at ensuring compliance with specific standards regarding the quality of care. These external control mechanisms, although necessary to ensure safety and quality, should not be confused with direct control of the internal management of hospitals by public authorities.

142. The management of the hospital, as an ASBL (non-profit organization), is subject to the Companies and Associations Code, which governs its internal activities like those of any private entity. The decision-making bodies of the hospital, namely the board of directors and the general assembly, are exclusively composed of private individuals, as stipulated in Articles 6, 7, and 11 of the association's bylaws. No statutory or legal provision requires the presence of representatives of public authorities within these bodies. Furthermore, decisions regarding financial strategy, personnel recruitment, or infrastructure management are made without interference from public authorities.

143. The legislative framework imposes certain obligations on hospitals in terms of tariffs and expenses, but this does not constitute direct financial control. Public authorities do not decide on the allocation of resources or the management of hospital budgets. These are the responsibility of the hospital's internal management bodies, which retain decision-making autonomy and their own accountability in financial management. Moreover, the general assembly of the hospital can decide, without interference from public authorities, to dissolve the hospital (Article 39 of the bylaws).

144. Finally, parliamentary debates regarding the Framework Law demonstrate that the legislator never considered the idea that hospitals in the form of ASBLs could be excluded from the regime of administrative fines provided for by the GDPR and the Framework Law. Even in more complex cases than the present one, where a hospital is managed by a Public Center for Social Action (“CPAS”), parliamentarians argued that such

Decision on the merits 166/2024 — 33/50

The hospital shall be subject to the regime of administrative fines: “Organizations that, in substance, carry out the same activities must be treated in the same manner, whether they belong to the public or private sector. Thus, it is for example unjustifiable that a hospital managed by a CPAS cannot be subjected to an administrative fine, while this could be the case for a hospital with the legal form of an ASBL” (emphasis added).

145. Thus, the hospital, although subject to regulation and inspections, remains an autonomous entity whose management cannot be equated to control by public authorities as defined by Article 5 of the Framework Law. The last condition of Article 5.3° of the Framework Law concerning management by public authorities is not fulfilled. In conclusion, the Litigation Chamber will retain the qualification of Y as a private law ASBL, with no link of preposition or mandate between the hospital and any public authority. This qualification prevents it from claiming the exception provided for in Article 221§2 of the Framework Law regarding the imposition of a fine based on Article 83 of the GDPR.

146. To eliminate any ambiguity, the defendant agrees to consider that Article 221§2 of the Framework Law, which provides that legal entities under public law that offer goods and/or services on a market are not exempt from administrative fines, should not be examined within the framework of the present

procedure. Indeed, it does not contest that the hospital is a legal entity under private law.

III.2. On the fine

147. The Litigation Chamber took into account the responses provided by the defendant to the sanction form in its analysis.

III.2.1. Reminder of the applicable legal provisions

148. As an independent administrative authority, the Litigation Chamber has the exclusive power to determine the corrective measures and appropriate sanctions in accordance with the relevant provisions of the GDPR and the LCA. This competence specifically derives from Articles 58 and 83 of the GDPR, as confirmed by the case law of the Market Court in its judgments of July 7, 2021, February 19, 2020, or even December 20, 2023, which highlighted the extent of the discretionary power of the Litigation Chamber regarding the choice of sanctions and the magnitude of the fine.

149. According to the guidelines of the EDPB and the GDPR, the supervisory authority has the discretionary power to impose a fine. The GDPR requires each supervisory authority to ensure that the administrative fines imposed are effective, proportionate, and dissuasive in each individual case (Article 83.1 of the GDPR).

150. Furthermore, when determining the amount of the fine, the supervisory authority must duly consider, for each individual case, several specific elements, such as “the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing concerned, as well as the number of affected individuals and the level of damage they have suffered” (Article 83.2.a) of the GDPR); as well as “the intentional or negligent nature of the infringement” (Article 83.2.b) of the GDPR); and “the categories of personal data concerned by the infringement” (Article 83.2.g) of the GDPR).

151. Consequently, any fine must be assessed taking into account all the factors set out in Article 83.2, points a) to k) of the GDPR, without exceeding the maximum legal amount set out in Articles 83.4 to 83.6 of the GDPR.

152. In accordance with Recital 148 of the GDPR, sanctions, including administrative fines, must be imposed in addition to or instead of appropriate measures in cases of serious breaches, even when it is the first finding of a breach. Thus, the fact that an infringing behavior is only observed for the first time in the case of a defendant does not prevent the Litigation Chamber from imposing an administrative fine, in accordance with Article 58.2.i) of the GDPR.

Decision on the merits 166/2024 — 35/50

III.2.2.

Reasons for the imposition of a fine

153. The CJEU recently ruled that in the event of a finding of a violation of personal data, the supervisory authority is not obliged to adopt a corrective measure, in particular an administrative fine, under Article 58.2 of the GDPR, when such intervention is not appropriate, necessary, or proportionate to remedy the identified shortcoming and ensure full compliance with this regulation³⁸.

154. The contentious chamber decides to impose an administrative fine because it considers that, in the specific circumstances of the case outlined below, taking into account the relevant criteria set out in Article 83.2 of the GDPR, a fine is appropriate. The aforementioned relevant criteria therefore apply not only when imposing a fine in accordance with Article 83, paragraph 1 of the GDPR but also when choosing between the different types of sanctions provided for in Article 58, paragraph 2 of the GDPR and Article 100 of the LCA³⁹.

155. To decide that an administrative fine was appropriate in this case, the contentious chamber considers the following criteria⁴⁰:

- The severity of the violations: Taking into account the sensitive nature of the data processed in this hospital context, the violations identified are particularly serious. Health data, due to their sensitive nature, benefit from enhanced protection and deserve a "higher" level of protection⁴¹. Hospitals are particularly vulnerable to data breaches. While some of these breaches are unavoidable despite the

implementation of appropriate technical and organizational measures, others can be prevented. To prevent them, the GDPR requires adapting these security measures to the risk presented by the processing, as well as implementing a DPIA to better manage risks upstream and determine appropriate measures. It is clear that the technical and organizational measures in place at the time of the data breach that occurred in 2021 were neither sufficient nor compliant with legal obligations, particularly those imposed by Article 32 of the GDPR. This breach is all the more serious as it occurs after a previous data breach of the same nature (ransomware). This circumstance should have prompted the hospital to reassess its risks and

38 Judgment of the CJEU, C-768/21, of September 26, 2024, ECLI:EU:C:2024:785

39 Regarding the conditions for assessing the appropriateness of imposing a fine, the contentious chamber recalls that these conditions are detailed in the Guidelines on the application and setting of administrative fines for the purposes of Regulation (EU) 2016/679, adopted on October 3, 2019, by the WP29 Working Group, accessible at the following link:

<https://ec.europa.eu/newsroom/article29/items/611237/en>

40 Market Court, 19th Chamber A, judgment of February 19, 2020, 2020/AR/1160, pp. 30-31; These criteria can also be used to assess the amount of the fine, in accordance with the aforementioned Guidelines of October 3, 2019.

41 See Article 9 and Recital 55 of the GDPR

Decision on the merits 166/2024 — 36/50

to adequately strengthen its security measures, including by conducting a DPIA (Data Protection Impact Assessment). The fact that a hospital, responsible for processing the personal data of 300,000 patients, did not take all necessary measures to prevent a second data breach constitutes a fault justifying the most dissuasive sanction.

- The duration of the breach: Appropriate technical and organizational measures to prevent a similar data breach should have been implemented no later than after the first data breach. However, the Litigation Chamber notes that many security measures were only put in place after the second data breach, namely 2 years and 6 months after this event, and that this implementation was incomplete. Given the risks faced by hospitals, and the higher level of protection attached to health data, hospitals cannot benefit from significant flexibility in the timelines for implementing their security and risk prevention measures. The hospital did not recognize the urgency of bringing all its security measures into compliance, even after its first data breach in 2019. This duration justifies an appropriate response from the Litigation Chamber.

- The necessary deterrent effect to prevent future breaches: The Litigation Chamber considers it regrettable that the hospital did not take appropriate technical and organizational measures in advance to do everything possible to avoid its second data breach. A simple warning would fail to produce the deterrent effect that the supervisory authorities must take into account in determining the appropriate sanction. A compliance order, taken alone, could lead the hospital and all Belgian hospitals to consider that the finding of such shortcomings by the Litigation Chamber constitutes the starting point of their compliance exercise, which would seriously undermine the security requirements of the GDPR. By choosing to impose a fine, the Litigation Chamber emphasizes the seriousness of these violations and the need for increased diligence in securing personal data in a hospital environment. It particularly wishes to demonstrate that data breaches resulting from serious and persistent negligence in risk management can lead to severe sanctions.

156. Given the context arising from such an assessment, the Litigation Chamber has determined that an administrative fine constitutes the appropriate sanction to send a strong message, not only to the defendant but also to all Belgian hospitals. This sanction is proof that non-compliance with the requirements of the GDPR results in severe penalties when the seriousness of the violation justifies it, as is the case here.

Decision on the merits 166/2024 — 37/50

III.2.3.

Starting amount for calculating the administrative fine

157. In order to impose an effective, proportionate, and dissuasive fine in any case, the supervisory authorities are expected to adjust administrative fines while remaining within the range provided in the EDPB guidelines until the maximum legal amount. This may lead to significant increases or decreases in the fine, depending on the circumstances of the specific case.

i. Classification based on violations under Article 83, paragraphs 4 and 5 of the GDPR

158. The GDPR distinguishes between two categories of violations: those punishable under Article 83.4 of the GDPR, on the one hand, and those punishable under Articles 83.5 and 83.6 of the GDPR, on the other. The first category of violations results in a maximum fine of 10 million EUR or 2% of the annual turnover of the company, with the higher amount being retained. As for the second category, it may result in a maximum fine of 20 million EUR or 4% of the annual turnover of the company, with the higher amount also being retained.

159. In this case, the Litigation Chamber notes the violation of several articles, namely the following:

- Article 35.3 of the GDPR, relating to the data protection impact assessment
- Article 32 of the GDPR, relating to the security of processing
- Article 5.1.f) of the GDPR, relating to the principle of integrity and confidentiality
- Article 24 of the GDPR, relating to the responsibility of the data controller

160. The highest fine applies, in accordance with Article 83.5.b) of the GDPR. Indeed, in the event of a violation of Article 5 (in this case, the principle of integrity and confidentiality), the Litigation Chamber may impose an administrative fine of up to 20,000,000 EUR or, in the case of a company, up to 4% of its total worldwide annual turnover for the preceding financial year, with the higher amount being retained.

161. In this case, it appears that the defendant's turnover is established at (.. EUR) for the year 2023, which precedes the year in which the decision in this case will be rendered and therefore constitutes the reference financial year.

Decision on the merits 166/2024 — 38/50

On this basis, the ceiling for the highest fine incurred amounts to 20,000,000 EUR.

ii. Severity of the violation in each specific case

162. The criteria presented below follow the methodology established by the Guidelines on the calculation of fines of the EDPB⁴⁴. The Litigation Chamber recalls that it is not required to examine criteria that are irrelevant⁴⁵.

Nature, severity, and duration of the violation (Article 83, paragraph 2, point a) of the GDPR)

163. Firstly, regarding the nature of the violations in this case, they consist of a series of breaches of various articles of the GDPR:

- Article 35.3 of the GDPR: The absence of a DPIA deprived the hospital of the ability to better map its IT systems and thus to initiate reflection on appropriate measures to address risks, particularly data breaches.
- Article 32 of the GDPR: The inadequacy of appropriate technical and organizational measures increases the risk of data breaches and reduces the data controller's ability to document them, jeopardizing the protection of personal data against unauthorized access.
- Article 5.1.f) of the GDPR: Inadequate security measures compromise the principle of integrity and confidentiality by making data vulnerable to unauthorized access, alteration, and disclosure. This directly undermines the application of Article 5.1.f) of the GDPR, which aims to ensure that personal data is processed securely.
- Article 24 of the GDPR: Insufficiency in security measures, including a lack of regular updates, reflects a failure of the data controller to comply with the obligations of Article 24 of the GDPR, which requires the implementation and continuous updating of appropriate measures to ensure and demonstrate compliance with the GDPR.

164. Secondly, regarding the severity of the violation, the Litigation Chamber will consider the following elements:

- Nature of the processing: The hospital context involves the management of sensitive data of vulnerable individuals on a large scale, processing for which utmost attention is required.

44 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR adopted on May 24, 2023 (v2.1), available at: <https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-042022-calculation-administrative-fines-under-fr>, see point 17

45 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR adopted on May 24, 2023 (v2.1), available at: <https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-042022-calculation-administrative-fines-under-fr>, see point 6

Decision on the merits 166/2024 — 39/50

Particular attention must be paid to security measures in order to limit risks to individuals. Indeed, the EDPB recalls in its guidelines that ransomware cases involve high risks, citing as an example a hospital that suffered a ransomware attack with data unavailability for 2 days.

- Purpose of the processing related to core activities: The processing subject to the investigation concerns the management of the defendant's IT systems, particularly the staff messaging systems and medical records, which are essential for the security of patient data and, consequently, the continuity of care.

- Number of individuals concerned: The hospital has 300,000 patients in its database, which constitutes the reference base of individuals affected by the breach. Indeed, due to the temporary unavailability of patient data, including from the software supporting medical records, the health data of the 300,000 patients of the hospital is part of the data breach. Furthermore, these 300,000 individuals are affected by the shortcomings identified by the Inspection Service, particularly the securing of the password access to their computerized medical records. Additionally, the hospital employees were also impacted by the data breach due to the temporary inaccessibility of their email accounts and computerized patient records, which are their main work tools.

- Level of damage: The Litigation Chamber finds that the insufficiency of the technical and organizational measures of the defendant contributed to making the data breach of 2021 possible. The continuity of patient care at the emergency service was disrupted for 3 days and caused the redirection of patients who needed urgent care to other hospitals. This data breach also prevented staff from accessing their email accounts for more than a week, and it took several days for the software that allows access to patient records to be operational again (at 95%) following this breach, which disrupted the continuity of care due to the unavailability of the necessary equipment for the proper functioning of the hospital. The level of damage determined is therefore moderate.

165. Thirdly, regarding the duration of the breach, the Litigation Chamber recalls that the duration of the breach in question is not relative to the duration of

EDPB, Guidelines 01/2021 on Examples concerning the notification of personal data breaches (v2), adopted on December 14, 2021, and available at the following link: https://www.edpb.europa.eu/system/files/2022-09/edpb_guidelines_012021_pdbnotification_adopted_fr.pdf. Regarding the temporary unavailability of data as a form of data breach: "Consequently, a security incident resulting in the temporary unavailability of personal data is also considered a type of breach, as the loss of access to data can have a significant impact on the rights and freedoms of individuals" (page 9).

In accordance with Recital 75 of the GDPR, the level of damage refers to physical, material damages, or moral harm.

Decision on the merits 166/2024 — 40/50

the data breach or its harmful consequences, as described in the previous paragraph. Indeed, the technical and organizational measures of the hospital should have been in place since the entry into force of the GDPR on May 25, 2018, and at a minimum since the first data breach on [date] 2019. The duration of the breach is considered from this last event until the data breach in September 2021, which marks the beginning of efforts to comply with security measures, amounting to 2 years and 6 months. This is a moderate duration.

Deliberate or negligent nature of the breach (Article 83, paragraph 2, point b) of the GDPR)

166. A distinction is made between breaches caused by negligence and breaches caused deliberately. The deliberate nature of a breach implies the meeting of two conditions, namely the knowledge of a breach as well as the intention to cause it. Negligence, on the other hand, is defined by the absence of intentionality in the commission of the offense, although the principle of diligence has not been respected.

167. The Contested Chamber specifies that a high threshold is set to consider a breach as deliberate. Furthermore, negligence can also be assessed by degrees.

168. In this case, there is no evidence of intent in the breaches committed. However, given that the processing of sensitive data constitutes the core activity of the defendant, and that the defendant had already suffered a data breach, the Contested Chamber considers that the defendant has committed serious negligence. This criterion reinforces the severity of the breach.

Categories of personal data concerned by the breach (Article 83, paragraph 2, point g) of the GDPR)

169. It appears from the case documents that sensitive data, the protection regime of which is ensured by Article 9 of the GDPR, including health data, are concerned by the breach. The breach of these categories of data reinforces the severity of the breach.

Classification of the severity of the breach and determination of the appropriate starting amount

170. The assessment of the above elements – namely the nature, severity, and duration of the breach, as well as the deliberate or negligent nature of the breach and the categories of personal data concerned – allows for the determination of the degree of severity of the breach as a whole. According to this evaluation, the severity of the breach can be classified as "low," "medium," or "high."

171. In this case, it should first be noted that the breach of Article 5 of the GDPR is among the breaches listed in Article 83.5 of the GDPR, thus falling under the higher level of Article 83 of the same Regulation.

172. The processing of sensitive data in question concerns the management of medical records of vulnerable individuals (patients) and electronic messages from hospital staff, which are essential for the continuity of care. Furthermore, it appears that 300,000 patients are included in the hospital's databases and that hospital employees are also affected by the data breach.

173. However, the level of proven damage remains relatively moderate, with unavailability of electronic messages from staff for 12 days, unavailability of computerized medical records for 3 days, and disruption of emergency services for 3 days as the main demonstrated impacts.

174. In any case, the breach committed by the defendant stems from serious negligence on their part, especially since the hospital suffered a first data breach in 2019. Most of the security measures that were implemented after the second data breach should have been in place since the entry into force of the GDPR.

175. In light of the elements presented above, the Contested Chamber concludes that the established breach is of medium severity. Therefore, for the calculation of the fine amount, a starting amount will be set between 10% and 20% of the maximum legal amount of 20,000,000 EUR provided for in Article 83.5 of the GDPR⁴⁹, that is, between 2,000,000 and 4,000,000 EUR.

176. In view of these elements, the Contested Chamber decides to set a starting amount at 15% of the maximum legal amount provided, namely 3,000,000 EUR.

49 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR, adopted on May 24, 2023 (v2.1), available at <https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-042022-calculation-administrative-fines-under-fr>, see point 60

Decision on the Merits 166/2024 — 42/50

iii. Turnover of the Data Controller and Additional Considerations Taken into Account by the Dispute Chamber to Determine the Amount of the Fine

177. The GDPR requires each supervisory authority to ensure that administrative fines imposed are effective, proportionate, and dissuasive in each individual case (Article 83.1 of the GDPR).

178. To achieve this, supervisory authorities should apply the definition of the concept of an

undertaking as adopted by the Court of Justice of the European Union (hereinafter "CJEU") for the purposes of Articles 101 and 102 TFEU, namely that the concept of an undertaking is understood as an economic unit that may be constituted by the parent company and all relevant subsidiaries. In accordance with EU law and jurisprudence, an undertaking must therefore be considered as an economic unit engaging in commercial/economic activities, regardless of its legal form. The objective is to ensure that sanctions are appropriate to the size and economic power of the undertaking.

179. Supervisory authorities are expected to adjust administrative fines based on the severity of the violation, while respecting the range provided in the EDPB guidelines up to the maximum legal amount. This may lead to significant increases or decreases in the fine, depending on the circumstances of the individual case.

180. Furthermore, Articles 83.4, 83.5, and 83.6 of the GDPR stipulate that the total global annual turnover for the previous financial year must be used for calculating the administrative fine. In this regard, the term "previous" must be interpreted in accordance with the CJEU's case law on competition law, such that the relevant event for calculating the fine is the supervisory authority's decision regarding the fine, and not the time of the sanctioned infringement.

181. As recalled in paragraph 160, the turnover of the defendant is established at (.. EUR) for the year 2023. This figure is derived from the annual accounts of ASBL Y (company number: [...]) as filed with the National Bank of Belgium (NBB) on [date] 2024.

50 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR, adopted on May 24, 2023 (v2.1), available at <https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-042022-calculation-administrative-fines-under>, see points 63 to 69; 112 to 131.

51 The case law of the Court of Justice of the European Communities provides the following definition: "the concept of an undertaking covers any entity engaged in an economic activity, irrespective of its legal status and the way it is financed" (Case C-41/90, Höfner and Elser/Macrotron, ECLI:EU:C:1991:161, paragraph 21). The concept of an undertaking "must be understood as designating an economic unit, even if this economic unit is legally constituted by different natural or legal persons" (Case C-217/05, Confederación Española de Empresarios de Estaciones de Servicio, ECLI:EU:C:2006:784, paragraph 40); CJEU, September 10, 2009, C-97/08 P, Akzo Nobel nv et al. v. Commission, ECLI:EU:C:2009:536, paragraphs 60-61.

Decision on the Merits 166/2024 — 43/50

182. The Dispute Chamber may consider adjusting the starting amount based on the annual turnover of the undertaking. For undertakings with an annual turnover between 50 and 100 million EUR, the guidelines on the calculation of fines allow for adjustments to be made based on an amount between 8% and 20% of the established starting amount.

183. In this case, the Dispute Chamber decides to adjust the amount from 3,000,000 EUR by 13% of the established starting amount, which amounts to 390,000 EUR. This calculation takes into account the reduction of the duration of the violation communicated to the defendant in the sanction form. The starting amount was initially set at 400,000 EUR and is reduced to 390,000 EUR to reflect the arguments put forward by the defendant in their responses to the sanction form.

184. In light of the preceding developments, the Dispute Chamber concretely decides to set the starting amount for the category of infringements at 390,000 EUR.

iv. Aggravating or Mitigating Circumstances

185. In accordance with Article 83 of the GDPR, the Dispute Chamber must also substantiate the imposition of an administrative fine in concrete terms, taking into account other aggravating or mitigating circumstances listed in Article 83.2 of the GDPR:

Measures Taken to Mitigate the Damage (Article 83.2.c of the GDPR)

186. As recalled by the EDPB guidelines regarding the calculation of administrative fines under the GDPR, "data controllers and processors are already required to 'implement technical and

organizational measures to ensure a level of security appropriate to the risk, conduct data protection impact assessments, and mitigate risks to the rights and freedoms of individuals resulting from the processing of personal data.' However, when a violation occurs, the data controller or processor 'should do everything in their power to reduce the consequences of the violation for the affected individual.'"

Decision on the Merits 166/2024 — 44/50

187. In this regard, the Contested Chamber holds that:

- Regarding the disruption of emergency services: the Hospital Emergency Plan was activated, allowing for the redirection of patients to other hospitals.
- Regarding the inability to access electronic messaging: the hospital implemented a "Patch" to resolve the vulnerability of the Exchange server and prevent such an intrusion from occurring again.
- Regarding the potential theft of sensitive data: the hospital directly disabled connections to and from the outside to limit the extent of the attack.
- Regarding the unavailability of the software containing medical records: the defendant established restoration tools to gradually restore the hospital's systems. Three days after the attack, the medical records management software was operational at 95%.

188. The Contested Chamber notes that measures were taken to mitigate the damage. This criterion constitutes a mitigating circumstance.

Health Context at the Time of the Violation (Article 83.2.k) of the GDPR)

189. The health context at the time of the violation, on [date] 2021, is taken into account in determining the amount of the fine. In the midst of the COVID-19 crisis, the hospital was facing an exceptional situation, requiring increased focus on providing care to patients. This major crisis may have limited the resources and attention available to fully ensure compliance with the requirements of the GDPR. This criterion constitutes a mitigating circumstance.

Energy Crisis and Inflation (Article 83.2.k) of the GDPR)

190. It is important to consider the exceptional economic circumstances faced by hospitals. Indeed, the energy crisis and the rapid rise in inflation have led to a significant increase in operating costs, placing greater financial pressure on the hospital's resources. These factors directly impact its ability to invest in enhanced security measures for data protection. In accordance with Article 83.2.k) of the GDPR, it is therefore legitimate to consider this unfavorable situation as a mitigating circumstance, justifying an adjustment of the fine so as not to further compromise the financial balance of the hospital and to allow for the continuity of its missions under difficult conditions.

Decision on the Merits 166/2024 — 45/50

191. Despite other proposals made by the defendant inviting the Contested Chamber to consider the severity of the violation differently, as well as an alternative interpretation of the aggravating and mitigating circumstances applicable, the Contested Chamber decides to maintain its analysis of the aggravating and mitigating circumstances as initially retained in the sanction form, with one exception. Indeed, the Contested Chamber has decided to take into account the energy crisis and inflation considered as a new mitigating circumstance. It has taken this modification into account to adjust the final amount of the fine.

v. Effectiveness, Proportionality, and Deterrence

192. The EDPB guidelines remind that the administrative fine imposed for GDPR violations referred to in Articles 83.4 to 83.6 must be effective, proportionate, and deterrent in each specific case. The supervisory authorities must verify whether the amount meets these criteria and adjust if necessary.

- Effectiveness

193. A fine is deemed effective if it achieves the objectives for which it was imposed, such as restoring compliance with the rules, sanctioning unlawful behavior, or both.

194. In this case, the fine aims to sanction the negligent and serious behavior of the defendant. Furthermore, it aims to deter other similar violations in the future. The prolonged duration of the violation, despite a previous data breach in 2019, demonstrates the need for a firm response from the Contested Chamber. Thus, the imposition of an administrative fine starting at 390,000 EUR constitutes an effective measure to achieve these objectives.

- Proportionality

195. The principle of proportionality, as defined by the GDPR, states that the measures adopted must not exceed what is appropriate and necessary to achieve the legitimate objectives of the regulation in question. In the case of fines, this means that their amount must not be disproportionate in relation to the aims pursued, the severity of the violation, as well as the size and financial capacity of the defendant.

54 EDPB - Guidelines 04/2022 on the calculation of administrative fines under the GDPR, adopted on May 24, 2023 (v2.1), available at <https://www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-042022-calculation-administrative-fines-under>, see point 6.

Decision on the merits 166/2024 — 46/50

the company concerned. Therefore, the supervisory authorities must ensure that the amount of the fine is proportionate to the violation assessed as a whole, taking into account various factors such as the financial capacity of the company to pay.

196. In certain exceptional circumstances, a reduction of the fine may be considered if imposing it would irreparably jeopardize the economic viability of the company concerned. This possibility is conceivable when objective evidence demonstrates an inability to pay. Furthermore, it is essential to analyze the risks by considering the specific social and economic context.

197. In the case at hand, several criteria indicate that the proposed fine is proportionate:

- Economic viability and financial capacity of the company: With a consolidated annual turnover of over 72 million euros for the fiscal year 2023, the defendant has sufficient financial capacity to bear a fine.

In order for the proposed fine not to compromise the economic viability of the hospital, given the financial difficulties presented by the defendant in support of documents in its sanction form, the contentious chamber grants a reduction of the initially planned fine. Indeed, even though the initial amount of the fine of 390,000 EUR represents only about 0.54% of a (rounded) turnover of 72,000,000 EUR, this amount must be reduced by about one-third in this case to primarily take into account (i) the financial difficulties of the hospital, particularly the conclusion of its recognition file as a "Company in Difficulty" and the appointment of a crisis manager, (ii) the new mitigating circumstance considered by the contentious chamber, namely the energy crisis and inflation, which also impact the financial capacity of the company.

- Evidence of loss of value: There is no indication that the imposition of the fine as revised would endanger the viability of the company, resulting in a significant loss of the value of its assets or threatening its ability to continue its operations in a viable manner. There must be a direct link between the fine and this loss of value, and it is not automatically accepted that bankruptcy or insolvency leads to such a loss, given the amount of the revised fine. In the absence of such tangible evidence demonstrating this correlation, an additional reduction of the fine does not seem justified.

- Specific social context: The social context of the time, marked by the COVID-19 health crisis in 2021, is a factor considered by the contentious chamber in determining the amount of the fine to be imposed.

Decision on the merits 166/2024 — 47/50

- Deterrence

198. The deterrent nature of the fine must have two dimensions. It must deter the person against whom the fine is imposed from repeating the violations found in the future, but also deter any other person from reproducing the infringing behaviors committed by the first.

199. Several factors determine the deterrent nature of a fine: the nature, the amount of the fine, and the likelihood of its imposition are determining elements in this regard. A fine must be sufficiently high to have a significant financial impact on the offending company while remaining proportionate to the

severity of the violation. In other words, the criterion of deterrence overlaps with that of effectiveness. 200. If a supervisory authority believes that a fine is not sufficiently deterrent, it may consider increasing it. In certain cases, it may even apply a deterrent multiplier to enhance its deterrent effect. This multiplier can be adjusted at the discretion of the supervisory authority to ensure that the deterrent objectives are fully achieved.

201. In this case, taking into account the reassessment of the duration of the violation, the new mitigating circumstance considered, as well as the financial capacity of the hospital, the final amount of the fine will therefore be definitively reassessed to 200,000 EUR.

202. This amount remains sufficiently deterrent to prevent the defendant from reoffending in the violation of GDPR rules. Moreover, it also seeks to deter other companies from committing similar violations. This fine, proportionate to the severity of the violation and taking into account the defendant's turnover, is designed to have both a specific and general deterrent effect.

III.3. On compliance orders

203. On the imposition of a compliance measure: Articles 58.2.d) of the GDPR and 100§9 of the LCA allow the contentious chamber to order the data controller to bring the processing operations into compliance with the provisions of the GDPR, if necessary, in a specific manner and within a determined timeframe.

204. In this case, the contentious chamber considers that certain technical and organizational measures, as well as a DPIA, have still not been implemented as of the date of...

Decision on the merits 166/2024 — 48/50

The decision. The Contentious Chamber will therefore also order the defendant to comply with the compliance orders set out in the following paragraph.

205. Compliance Orders: The Contentious Chamber orders the defendant to comply with the following points within 90 days from the notification of the decision:

a. Conduct a data protection impact assessment, based on Article 35.3 of the GDPR. The Contentious Chamber reminds that the content of this DPIA must at a minimum include the conditions set out in Article 35.7 of the GDPR, including a systematic description of the intended processing operations and the measures envisaged to address the risks.

b. Establish a "clear and precise policy regarding information security and privacy" (paragraph 81 of the decision), in accordance with the information security policy of March 3, 2022, to ensure the security of the processing operations implemented by the defendant, in accordance with Articles 5.1.f) and 32 of the GDPR.

c. Implement a regular training/awareness program for employees on the GDPR, so that the hospital can ensure at a minimum that all its staff are aware of the basic principles of personal data processing, including the principle of integrity and confidentiality. This requirement arises from the application of Articles 32, 5.1.f) and 24 of the GDPR.

d. Strengthen the length of the password for access to the computerized patient file to ensure compliance with Articles 32, 5.1.f) and 24 of the GDPR.

Decision on the merits 166/2024 — 50/50

in accordance with Article 1034quinquies of the Judicial Code, or via the e-Deposit information system of the Ministry of Justice (Article 32ter of the Judicial Code).

(sé). Hielke HIJMANS

President of the Contentious Chamber

The request, accompanied by its annex, is sent, in as many copies as there are parties involved, by registered letter to the clerk of the court or filed with the registry.